

Actividad 07

File path traversal, simple case

Path traversal directo (secuencias relativas)

Nombre: Tristán Rivera Magdalena Yesenia

Matrícula: 174702

Materia / Grupo: CNO IV — Programación WAP · T37A

Profesor: Servando López Contreras

Herramienta: Burp Suite Community Edition

URL: <https://portswigger.net/web-security/file-path-traversal/lab-simple>

OBJETIVO

Leer el contenido de `/etc/passwd` explotando el parámetro `filename` del endpoint de imágenes, que no aplica ninguna validación sobre la ruta recibida.

EXPLICACIÓN TÉCNICA DE LA VULNERABILIDAD

La aplicación arma la ruta del archivo concatenando directamente el valor de `filename` a un directorio base (algo como `/var/www/images/`), sin sanitizar secuencias `../`. Al subir tres niveles de directorio con `../../../` se llega a la raíz del sistema de archivos, desde donde se puede referenciar `etc/passwd` directamente.

PROCEDIMIENTO PASO A PASO

1. Entrar al lab y activar **Intercept on** en Burp Suite (pestaña Proxy).
2. Hacer clic en cualquier producto de la tienda para que el navegador pida su imagen.
3. Cuando Burp intercepte `GET /image?filename=N.jpg`, mandarla a Repeater (clic derecho → Send to Repeater).
4. En Repeater, sustituir el valor de `filename` por el payload.
5. Enviar (Send) y revisar que el Response devuelva el contenido de `/etc/passwd`.
6. Confirmar el badge "Lab solved" en la esquina superior derecha del navegador.

PAYLOAD UTILIZADO

```
GET /image?filename=../../../etc/passwd HTTP/2
```

Cada `../` sube un nivel de directorio; tres repeticiones son suficientes para llegar a la raíz desde `/var/www/images/` y acceder a `/etc/passwd`. El servidor no valida ni filtra esta secuencia en ningún punto.

MITIGACIÓN RECOMENDADA

Nunca construir rutas de archivo concatenando input del usuario directamente. Usar un mapa de identificadores a archivos permitidos (whitelist), o validar la ruta canónica resultante contra el directorio base permitido.

